

# REMÉDIATION : SÉCURISATION DE L'ANNUAIRE LAB.LOCAL

## PHASE 1 : URGENCES ABSOLUES (ACTIONS IMMÉDIATES)

### 1. Désactivation du Spooler d'impression

**Pourquoi ?** Empêcher les attaques de type *PrintNightmare*.

- **Action :** Sur ton contrôleur de domaine (DC), ouvre PowerShell en admin :

`Stop-Service -Name Spooler`

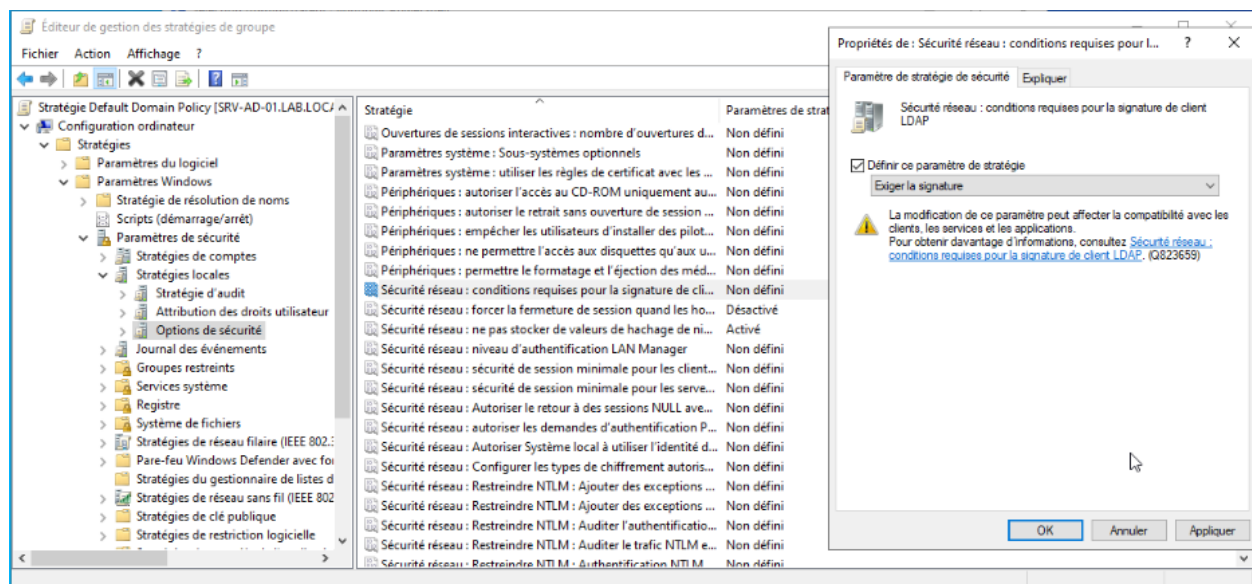
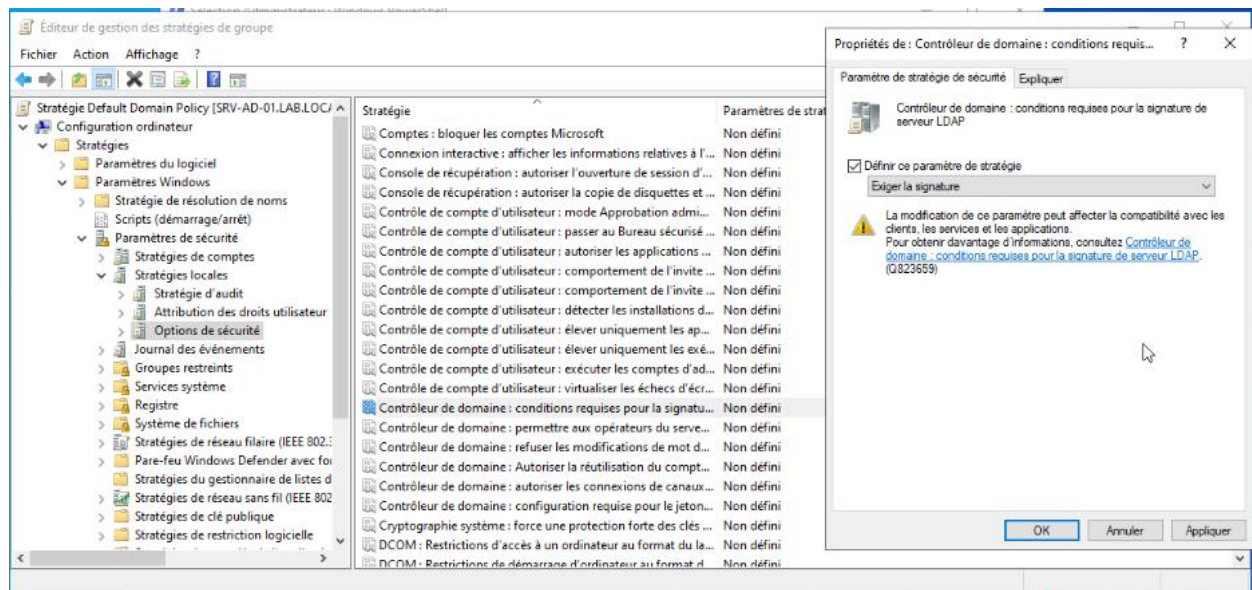
`Set-Service -Name Spooler -StartupType Disabled`

```
PS C:\Users\Administrateur> Stop-Service -Name Spooler
PS C:\Users\Administrateur> Set-Service -Name Spooler -StartupType Disabled
PS C:\Users\Administrateur>
```

### 2. Exiger la Signature LDAP

**Pourquoi ?** Bloquer les attaques de l'homme du milieu (MiTM).

- **Chemin GPO :** Gestion des stratégies de groupe > Default Domain Controllers Policy > Modifier.
- **Navigation :** Configuration ordi > Stratégies > Paramètres Windows > Paramètres de sécurité > **Stratégies locales** > Options de sécurité.
- **Réglages :**
  - *Contrôleur de domaine : exigences de signature de serveur LDAP* -> **Exiger la signature.**
  - *Sécurité réseau : exigences de signature de client LDAP* -> **Exiger la signature.**



## PHASE 2 : DURCISSEMENT TECHNIQUE (PINGCASTLE)

### 3. Windows LAPS (Local Administrator Password Solution)

**Pourquoi ?** Un mot de passe unique et chiffré par PC pour stopper le déplacement latéral.

- **Étape 1 (Schéma) :** PowerShell Admin : Update-LapsADSchema (valider par "O").
- **Étape 2 (OU) :** Créer une OU (ex: Mes\_Ordinateurs) dans dsa.msc et y glisser les PC.
- **Étape 3 (Droits) :** PowerShell : Set-LapsADComputerSelfPermission -Identity "OU=Mes\_Ordinateurs,DC=lab,DC=local".
- **Étape 4 (GPO) :** Créer une GPO liée à cette OU. Chemin : Modèles d'administration > Système > LAPS.

- Configure password backup directory -> **Activé (Active Directory).**
- Enable password encryption -> **Activé.**

```
C:\Users\Administrateur> Update-LapsADSchema

The 'ms-LAPS-Password' schema attribute needs to be added to the AD schema.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui

The 'ms-LAPS-PasswordExpirationTime' schema attribute needs to be added to the AD schema.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui

The 'ms-LAPS-EncryptedPassword' schema attribute needs to be added to the AD schema.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui

The 'ms-LAPS-EncryptedPasswordHistory' schema attribute needs to be added to the AD schema.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui

The 'ms-LAPS-EncryptedDSRMPassword' schema attribute needs to be added to the AD schema.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui

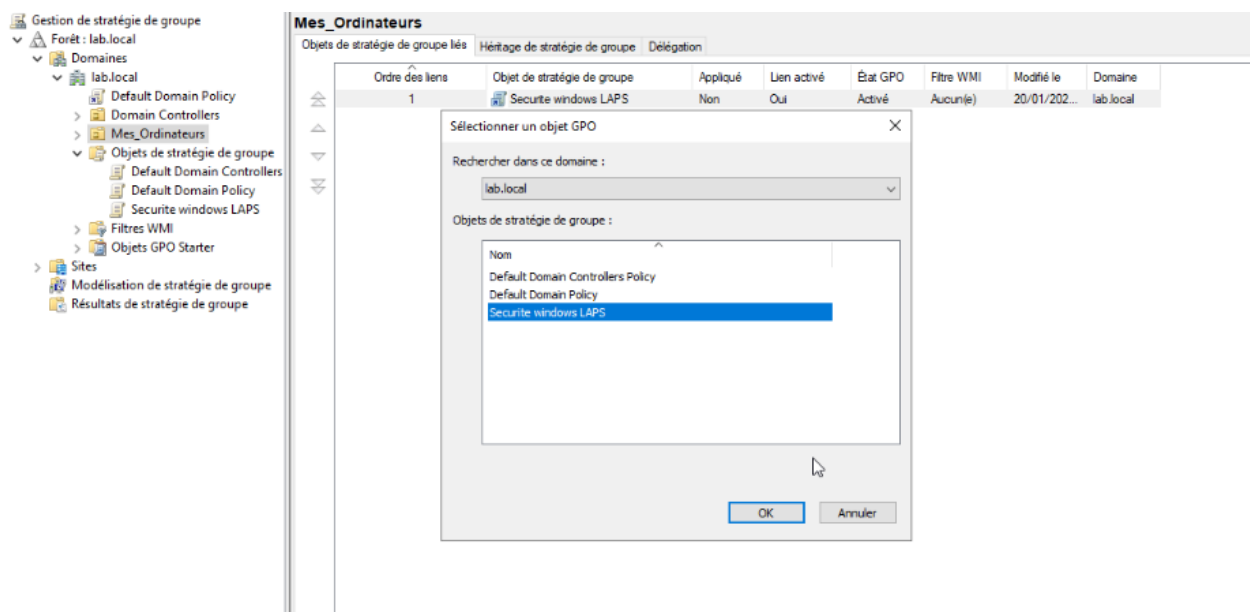
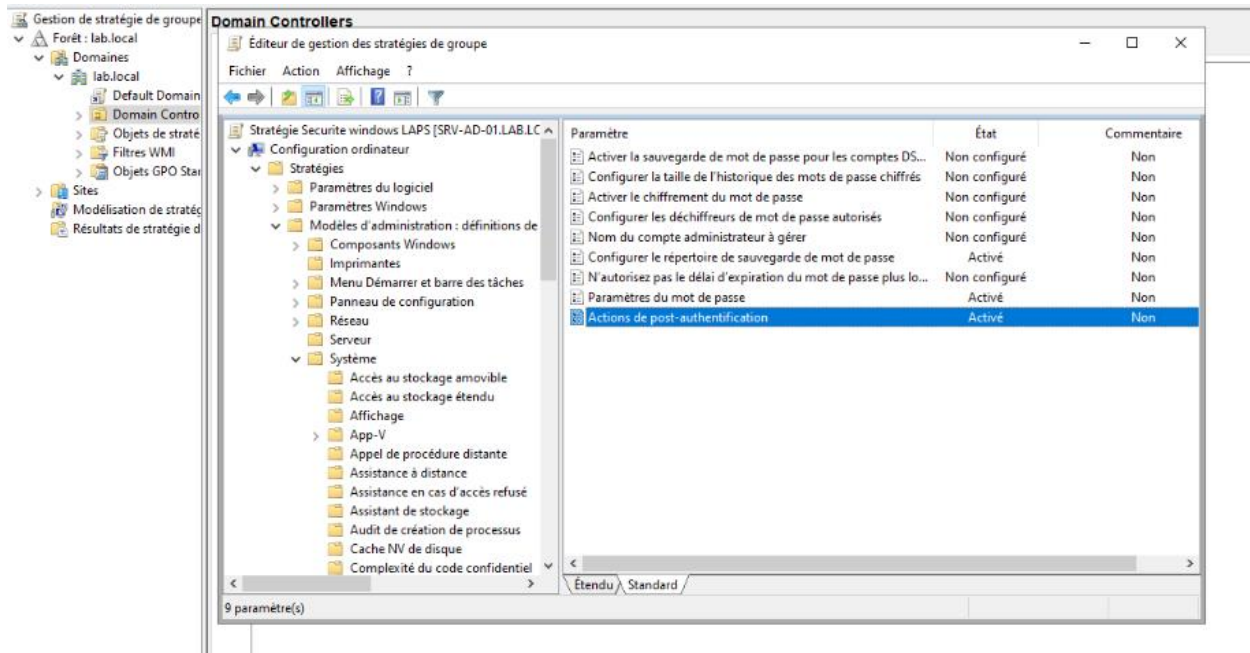
The 'ms-LAPS-EncryptedDSRMPasswordHistory' schema attribute needs to be added to the AD schema.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui

The 'ms-LAPS-Encrypted-Password-Attributes' extended right needs to be added to AD.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui

The mayContain attribute on the 'computer' class schema attribute needs to be updated in the AD schema.
Do you want to proceed?
[0] Oui [T] Oui pour tout [N] Non [U] Non pour tout [S] Suspendre [?] Aide (la valeur par défaut est « 0 ») : oui
PS C:\Users\Administrateur>
```

The screenshot shows the Group Policy Management console for the 'lab.local' domain. The 'Domain Controllers' group policy list is displayed, showing a single policy named 'Default Domain Controllers Policy'. A dialog box titled 'Nouvel objet GPO' is open, allowing the creation of a new Group Policy Object. The 'Nom' field contains 'Sécurité windows LAPS' and the 'Objet Starter GPO source' is set to '(aucun)'. The 'OK' button is highlighted.

| Ordre des liens | Objet de stratégie de groupe      | Appliqué | Lien activé | État GPO | Filtre WMI | Modifié le   | Domaine   |
|-----------------|-----------------------------------|----------|-------------|----------|------------|--------------|-----------|
| 1               | Default Domain Controllers Policy | Non      | Oui         | Activé   | Aucun(e)   | 06/01/202... | lab.local |



## 4. Restriction Kerberos & NTLM

Pourquoi ? Supprimer les chiffrements faibles (RC4/DES).

- **Chemin** : Même dossier "Options de sécurité" que pour le LDAP.
- **Kerberos** : *Sécurité réseau : configurer les types de chiffrement autorisés pour Kerberos* -> Cocher **uniquement** AES128, AES256 et Futurs types.
- **NTLM** : *Sécurité réseau : restreindre NTLM : authentification NTLM dans ce domaine* -> **Tout refuser** (après audit).

## PHASE 3 : SÉCURISATION DES IDENTITÉS (PURPLE KNIGHT)

### 5. Comptes à privilèges

Action pour chaque compte Admin :

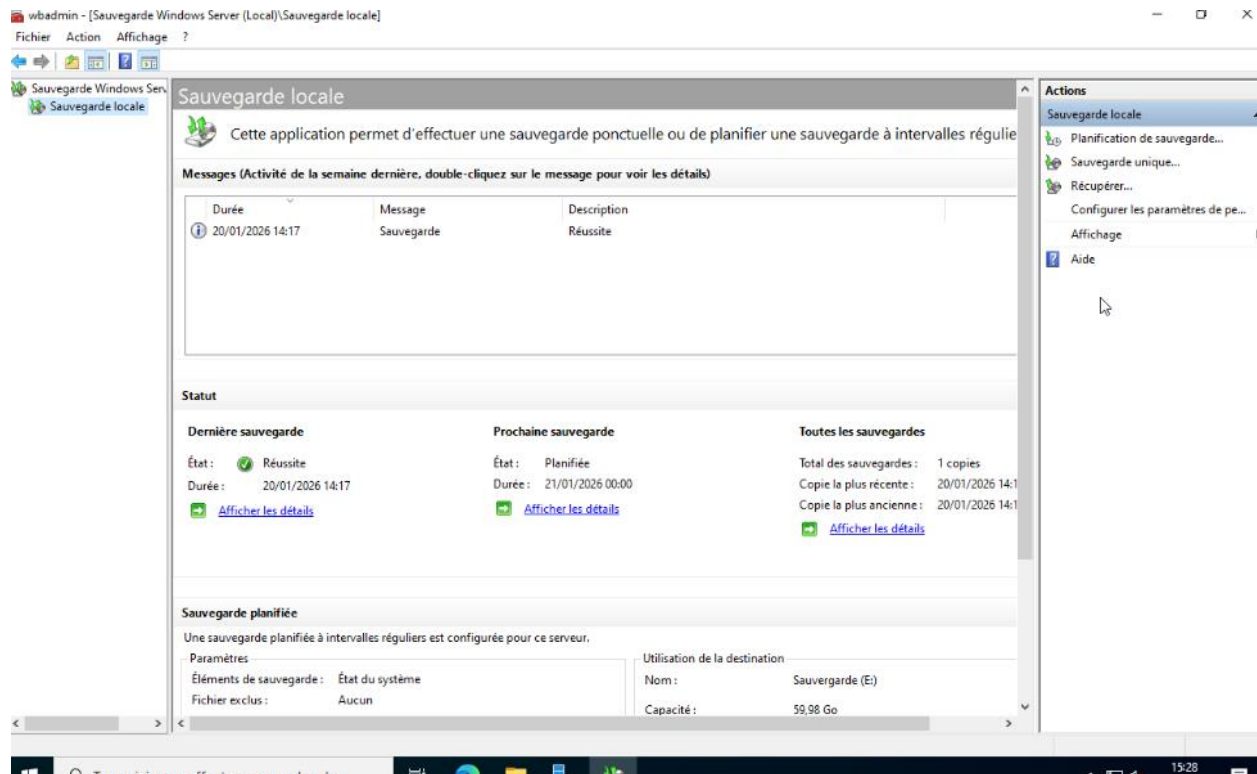
- **Sensibilité** : Propriétés du compte > Onglet Compte > Coche "**Le compte est sensible et ne peut pas être délégué**".
- **Groupe Protected Users** : Ajouter ces comptes comme membres du groupe **Protected Users**.

## PHASE 4 : RÉSILIENCE & MAINTENANCE

### 6. Sauvegarde de l'État du Système (System State)

Pourquoi ? le dernier backup a 13 jours. Il faut une sauvegarde toutes les 24h.

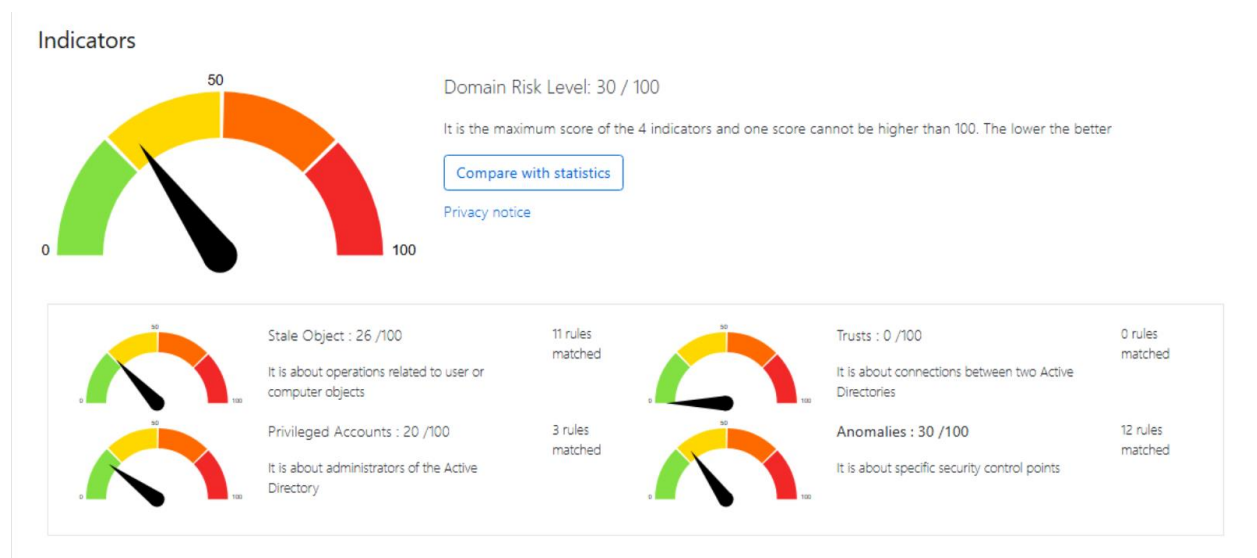
- **Étape Proxmox** : Ajouter un nouveau disque dur (ex: 60 Go) à la VM via l'onglet **Hardware**.
- **Étape Windows** : Initialiser le disque dans diskmgmt.msc (Lettre **E:**, format GPT).
- **Étape Logiciel** :
  1. Ouvrir **Sauvegarde Windows Server**.
  2. **Planification de sauvegarde** > Personnalisée.
  3. Ajouter l'élément "**État du système**" (System State).
  4. Destination : **Volume local (E:)**.

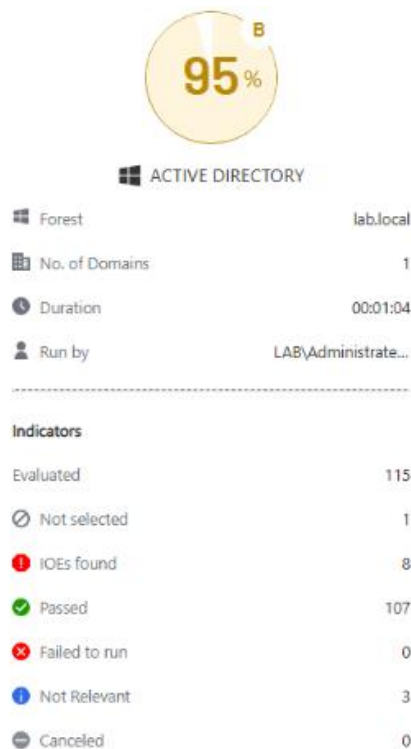


## 7. Limitation du Quota de machines (ms-DS-MachineAccountQuota)

Action : PowerShell :

```
Set-ADDomain -Identity (Get-ADDomain).distinguishedName -Replace @"{"ms-DS-MachineAccountQuota"=0}
```





## CRITICAL IOEs FOUND

### Privileged Users with Weak Password Policy

This indicator looks for privileged users in each domain that don't have a strong password policy enforced, according to ...

[Read More](#)

## 1. Renforcer la politique de mots de passe (Action 1)

C'est ce réglage qui me bloque actuellement à **73%** sur mes audits.

- Je vais modifier la **Default Domain Policy**.
- Je suis ce chemin : Configuration ordinateur > Paramètres Windows > Paramètres de sécurité > Stratégies de comptes > Stratégie de mots de passe.
- Je change la **Longueur minimale du mot de passe** pour la passer à **12** (actuellement, le rapport indique qu'elle est à moins de 8).

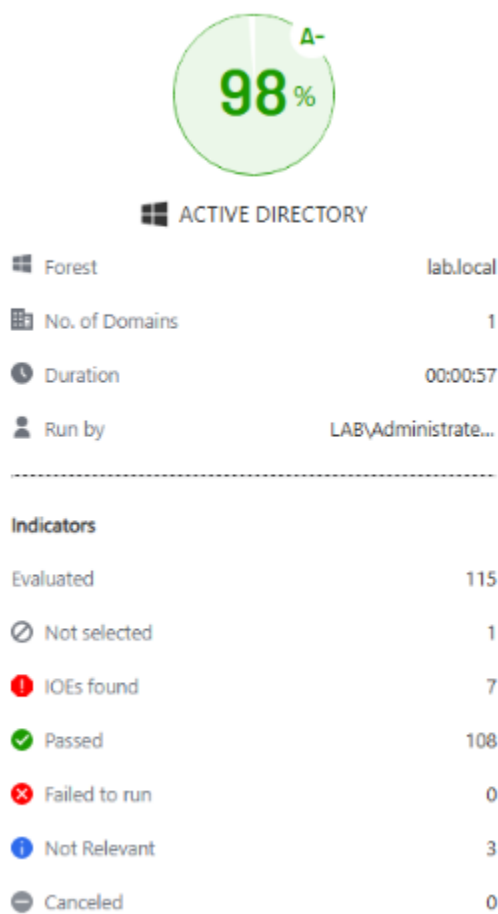


## 2. Activer la Corbeille AD (Action 2)

Puisque j'ai vérifié que mes GPO d'ordinateur sont bien appliquées, il ne me manque plus qu'une étape pour que mon rapport **PingCastle** passe au vert sur la partie résilience :

- Je vais ouvrir **PowerShell** en administrateur.
- Je tape cette commande pour activer la **Corbeille Active Directory** (ce qui est irréversible mais indispensable) :

```
Enable-ADOptionalFeature 'Recycle Bin Feature' -Scope ForestOrConfigurationSet -Target lab.local
```





## CRITICAL IOEs FOUND

None

## ADDITIONAL IOEs FOUND

### Indicators



Domain Risk Level: 26 / 100

It is the maximum score of the 4 indicators and one score cannot be higher than 100. The lower the better

[Compare with statistics](#)

[Privacy notice](#)



Stale Object : 26 /100

It is about operations related to user or computer objects



Privileged Accounts : 10 /100

It is about administrators of the Active Directory

11 rules  
matched

2 rules  
matched



Trusts : 0 /100

It is about connections between two Active Directories

0 rules  
matched



Anomalies : 20 /100

It is about specific security control points

11 rules  
matched

6